

scanning tools; approaching a lawyer with the list shouldn't be difficult after that. If you are a large enterprise, you will have your own legal team and if you are a small group, look for support from incubation companies," he says.

He explains that it is still fine to trust the instincts of the technical team head: "If your technical head says that it's fine to be used as per my knowledge, go ahead and build your software. Before delivery, just ensure the scan is done, and list all the licences and copyrights. Later, you may seek legal advice to see which licences can help you achieve the compliances."

Compliance is a multi-step process. Apart from the version upgrades, your old version of software may also have some new vulnerability, which is found later. All the vulnerabilities cannot be found in the initial release days of a version of a component. Some security risks pop up after use. Hence, it's important to either follow various kinds of checks manually depending on your product line or find these automatically using tools. This helps to fix security risks immediately and to keep a constant check on licences.

## A way forward

There are tools available that reveal the components used in a product, but if there is lack of understanding about the licence implications, there can be a potential risk in using them. Companies that have an interest in using standardised open source can take the help of global projects like OpenChain, which is hosted by the Linux Foundation. "It tells you how to manage the supply chain of software and, more importantly, how to prove to your customers that there is no risk in using the software. It's an ISO standard now; you can get a certification that says you have got the processes that manage open source software development. This gives a lot of confidence to customers," Callinan explains.

## Well-known litigations with respect to open source compliance

- **CoKinetic vs Panasonic Avionics:** CoKinetic and Panasonic Avionics were both developing Linux based flight entertainment systems. Panasonic incorporated a massive amount of open source modules, programs, and libraries into its Linux based core software without distributing the source code. CoKinetic claimed that Panasonic was following monopolistic practices and had intentionally violated the GPLv2 open source licensing requirements, preventing its competitors from being able to build the software for in-flight entertainment services.
- **Software Freedom Conservancy vs Vizio:** Software Freedom Conservancy (SFC) has filed a lawsuit against California TV manufacturer Vizio Inc. alleging repeated failures to fulfill the requirements of the General Public License (GPL). In its complaint, SFC alleges that Vizio's TV products, built on its SmartCast system, contain software from the Linux kernel and several open source programs. It further states the sale of the TVs constitutes unfair distribution of the GPL licensed software leading to breach of obligations. SFC claims the source code for the SmartCast system must be made available by Vizio. This case highlights the importance of understanding the requirements and risks of using open source software.

According to experts, OpenChain ceates global transparency and uniformity with respect to open source compliance. It helps organisations to customise and developers to comply with various licences.

"As the group lead for the open source education board at OpenChain, we are developing an open chain compliant or awareness programme that will be available as Web based training. We are planning to host it in the Linux Foundation free of cost. This certification will help achieve awareness on the minimum criteria for compliance. We also have some ideas about creating a FAQ kind of playbook for open source compliance. Currently, a playbook for medium scale companies is available and more upgrades will be done. The

course titled 'LFC193 - Introduction to Open Source License Compliance Management' is now available and the advanced version of LFC194 will be launched soon. Developers just have to continue participating and contributing to all the OpenChain education or any tooling meetings," says Mukundaraj.

Callinan warns that stricter regulations are forcing tech companies to submit their SBOM. The US White House has imposed these regulations to improve the nation's cyber security, and this can affect all software exported to that country. "There will be a point where software solutions cannot be exported to Europe or the US, unless they comply by these regulations. So, start complying with them right away," he concludes. 

The article has been compiled from a panel discussion held at Open Source India 2021 (virtual). The panelists were Biju K. Nair, founding partner, Legalitech (moderator); Aykut Avci, global license compliance manager, iText Software; Martin Callinan, director, Source Code Control India Pvt Ltd; Balakrishna Mukundaraj, associate project manager, Bosch Global Software Technologies Pvt Ltd; and Sriharsha Narayanam, lead architect, Huawei Technologies India Pvt Ltd.

*Transcribed and curated by Abbinaya Kuzhanthaivel*